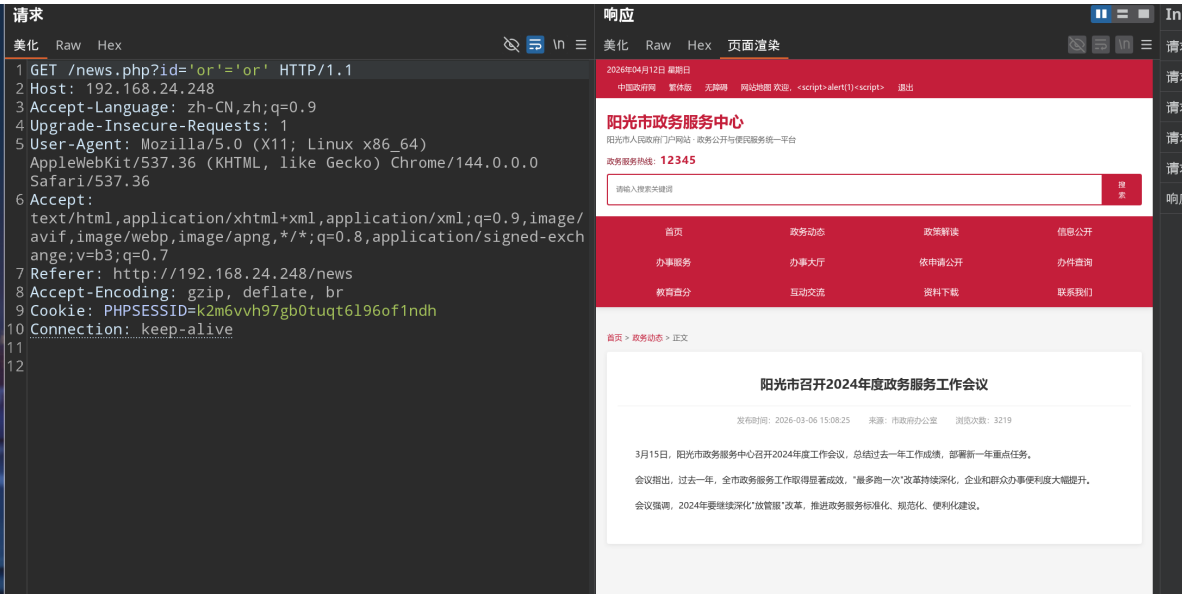


政府动态这，id传参，可以看到表达式逻辑真时访问id为1的新闻，有sql注入风险



admin账户弱密码123456

敏感信息泄露

数据库备份backup.sql泄露，可以看到数据库整个信息，以及api token

```
-- 漏洞点12：敏感文件泄露
-- 数据库备份文件暴露在web目录
-- 难度：简单

-- Database: govctf
-- Server version: 5.7.33

CREATE DATABASE IF NOT EXISTS govctf;
USE govctf;

-- 管理员表备份
CREATE TABLE admin_users (
  id int(11) NOT NULL AUTO_INCREMENT,
  username varchar(50) NOT NULL,
  password varchar(255) NOT NULL,
  role varchar(20) DEFAULT 'admin',
  PRIMARY KEY (id)
);

-- 备份数据（包含密码哈希）
INSERT INTO admin_users VALUES
(1, 'admin',
'$2y$10$92IXUnpkj00rOQ5byMi.Ye4oKoEa3Ro9llC/.og/at2.uhewG/igi', 'admin'),
(2, 'editor',
'$2y$10$92IXUnpkj00rOQ5byMi.Ye4oKoEa3Ro9llC/.og/at2.uhewG/igi', 'editor'),
(3, 'test',
'$2y$10$TKh8H1.PfQx37YgCzwIKb.KjNyWgaHb9cbcoQgdIVFlYg7B77UdFm', 'test');

-- 数据库连接信息
-- Host: 192.168.1.20
-- User: govctf
```

```
-- Pass: GovCtf@2024!

-- API接口调试token（内部使用）
-- api_token: yg_api_s3cret_2024
```

泄露phpinfo.php敏感文件，可以看到网站配置

PHP Version 7.3.4

System	Windows NT DESKTOP-BUU38B3 10.0 build 18363 (Windows 10) AMD64
Build Date	Apr 2 2019 21:50:57
Compiler	MSVC15 (Visual C++ 2017)
Architecture	x64
Configure Command	ccscript /nologo configure.js "--enable-snapshot-build" "--enable-debug-pack" "--disable-zts" "--with-pdo-oci=c:\php-snap-build\deps_aux\oracle\x64\instantclient_12_1\sdk,shared" "--with-oci8-12c=c:\php-snap-build\deps_aux\oracle\x64\instantclient_12_1\sdk,shared" "--enable-object-out-dir=../obj/" "--enable-com-dotnet=shared" "--without-analyzer" "--with-pgo"
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	C:\Windows
Loaded Configuration File	C:\phpstudy_pro\Extensions\php\php7.3.4nts\php.ini
Scan this dir for additional .ini files	(none)
Additional .ini files parsed	(none)
PHP API	20180731
PHP Extension	20180731
Zend Extension	320180731
Zend Extension Build	API320180731,NTS,VC15
PHP Extension Build	API20180731,NTS,VC15
Debug Build	no
Thread Safety	disabled
Zend Signal Handling	disabled
Zend Memory Manager	enabled
Zend Multibyte Support	provided by mbstring
IPv6 Support	enabled
DTrace Support	disabled
Registered PHP Streams	php, file, glob, data, http, ftp, zip, compress.zlib, https, ftps, phar
Registered Stream Socket Transports	tcp, udp, ssl, tls, tlsv1.0, tlsv1.1, tlsv1.2
Registered Stream Filters	convert.iconv.*, string.rot13, string.toupper, string.tolower, string.strip_tags, convert.*, consumed, dechunk, zlib.*

This program makes use of the Zend Scripting Language Engine:
Zend Engine v3.3.4, Copyright (c) 1998-2018 Zend Technologies



robots.txt泄露，同时.git泄露，但是不可访问

```
User-agent: *  
Disallow: /1709280000?  
Disallow: /old/  
Disallow: /.git/
```

 |  查看器  控制台  调试器  网络  样

LOAD



SPLIT

EXECUTE

TEST



URL

http://192.168.24.248/robots.txt